

Relatório de Segurança da Plataforma

Avaliação técnica de segurança da plataforma de monitoramento e gestão predial Beeldings — controles implementados e resultado das varreduras automatizadas.

✓ **Nenhuma vulnerabilidade crítica ou alta em aberto**

**Data da
avaliação**

14 de agosto de
2026

Escopo

Aplicação web, API e
dependências

Classificação

Confidencial — uso do
cliente

1. Resumo executivo

A plataforma Beeldings foi submetida a uma rodada completa de varreduras automatizadas de segurança em 14/08/2026, cobrindo três frentes: **vulnerabilidades em dependências de software** (SCA), **análise estática do código-fonte** (SAST) e **rastreamento de fluxo de dados sensíveis**. Todas as vulnerabilidades de severidade alta identificadas em bibliotecas de terceiros foram corrigidas na mesma data, e a varredura de confirmação registrou **zero vulnerabilidades críticas e zero altas em aberto**.



2. Metodologia

Varredura	O que verifica	Resultado
Análise de dependências (SCA)	Vulnerabilidades conhecidas (CVEs) em todas as bibliotecas de terceiros utilizadas pela plataforma.	0 críticas / 0 altas
Análise estática de código (SAST)	Padrões inseguros no código-fonte: injeções, exposição de credenciais, uso incorreto de criptografia.	Sem achados relevantes
Fluxo de dados sensíveis	Vazamento de dados pessoais ou sensíveis para logs, arquivos ou serviços externos.	Sem achados relevantes

3. Vulnerabilidades corrigidas nesta rodada

As nove vulnerabilidades abaixo estavam em bibliotecas de terceiros (não no código da plataforma) e foram **corrigidas em 14/08/2026** por atualização para as versões oficiais seguras, com verificação posterior:

Componente	Vulnerabilidade (CVE)	Severidade	Situação
Next.js (framework web)	CVE-2026-64649 — Server-Side Request Forgery em Server Actions	Alta	Corrigida

Next.js (framework web)	CVE-2026-64645 — Server-Side Request Forgery via rewrites	Alta	Corrigida
Next.js (framework web)	CVE-2026-64642 — Bypass de middleware/proxy no App Router	Alta	Corrigida
Next.js (framework web)	CVE-2026-64641 — Negação de serviço em Server Actions	Alta	Corrigida
nanoid (geração de IDs)	CVE-2026-67213 — Laço infinito com tamanho zero	Alta	Corrigida
nanoid (geração de IDs)	CVE-2026-67214 — Laço infinito com tamanho negativo	Alta	Corrigida
brace-expansion (utilitário)	CVE-2026-14257 — Negação de serviço por expansão ilimitada	Alta	Corrigida
brace-expansion (utilitário)	CVE-2026-13149 — Negação de serviço por expansão exponencial	Alta	Corrigida
brace-expansion (utilitário)	CVE-2026-69152 — Bypass da mitigação do CVE-2026-14257	Alta	Corrigida

4. Controles de segurança implementados

4.1 Autenticação e sessões

- Senhas armazenadas apenas com **hash criptográfico** — nunca em texto claro.
- Sessão em **cookie HttpOnly**: o token de acesso não é legível por scripts no navegador, mitigando roubo de sessão via XSS.
- **Proteção anti-robô (Cloudflare Turnstile)** na tela de login do ambiente de produção.
- **Limite de tentativas** (rate limiting) contra ataques de força bruta, com identificação correta do IP de origem.

4.2 Isolamento entre clientes (multi-tenant)

- Todos os dados são **segregados por cliente**: cada organização acessa exclusivamente seus próprios sites, equipamentos, alarmes e relatórios.
- O escopo do cliente é resolvido de forma centralizada no servidor a cada requisição — nunca confiado ao navegador.
- Contas de clientes inativados são bloqueadas imediatamente, inclusive nas conexões em tempo real já abertas.

4.3 Proteção de operações críticas

- Exclusões de dados críticos exigem **reconfirmação de senha**, com autorização de curta validade (5 minutos) e uso único.
- Comandos de escrita em equipamentos passam por validação de permissão e são bloqueados em pontos sem comunicação.
- **Trilha de auditoria**: ações relevantes (login, comandos, alterações) são registradas com autor, data/hora e resultado — incluindo tentativas de login que falharam.

4.4 Proteção de dados e comunicação

- Todo o tráfego externo ocorre exclusivamente sobre **HTTPS (TLS)**.
- Credenciais de câmeras e equipamentos são armazenadas **criptografadas (AES-GCM)** e só decifradas no momento do uso.
- Comunicação com gateways de campo via **MQTT autenticado**, com credenciais individuais por dispositivo e listas de controle de acesso (ACL) restritas por tópico.
- Segredos e chaves de API ficam em **cofre de variáveis de ambiente** — fora do código-fonte e do controle de versão.

- Cabeçalhos de segurança HTTP (Helmet) e política de origens (CORS) centralizada e restritiva.

5. Recomendações e evolução contínua

A segurança é tratada como processo contínuo na plataforma. As frentes de aprimoramento já mapeadas incluem:

- **Testes automatizados de isolamento entre clientes**, garantindo de forma permanente que nenhum cadastro exiba dados de outra organização (já planejado no roadmap).
- **Políticas formais de retenção** para registros de auditoria e histórico de eventos.
- **Varreduras periódicas de dependências** a cada ciclo de publicação, mantendo o resultado de zero vulnerabilidades críticas/altas.
- Abertura a **testes de intrusão (pentest) independentes** contratados pelo cliente, com apoio técnico da equipe Beeldings.

6. Escopo e limitações

Este relatório documenta os **controles de segurança implementados** e o resultado de **varreduras automatizadas** (análise de dependências, análise estática de código e rastreamento de fluxo de dados) executadas em 14/08/2026. Varreduras automatizadas não substituem um teste de intrusão (pentest) manual conduzido por empresa especializada; a plataforma está preparada para receber esse tipo de avaliação quando o cliente desejar.

7. Conclusão

Na data desta avaliação, a plataforma Beeldings encontra-se **sem vulnerabilidades críticas ou altas conhecidas em aberto**. Os controles essenciais de segurança — autenticação robusta, isolamento total entre clientes, criptografia de credenciais, trilha de auditoria e proteção de operações críticas — estão implementados e ativos no ambiente de produção. A equipe mantém rotina de atualização de dependências e correção imediata de vulnerabilidades divulgadas publicamente, como demonstrado nesta rodada.

Documento gerado pela equipe técnica da plataforma Beeldings.

Dúvidas técnicas sobre este relatório podem ser encaminhadas ao responsável pela conta.